Nightingale Shared Care Note

A local-first communication and trust system for one actionable longitudinal patient record

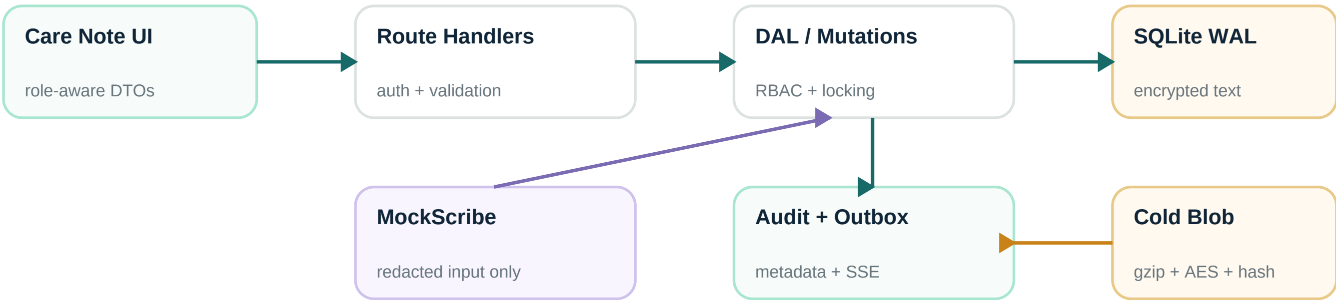
1 · Product thesis

The failure is not absence of notes; it is the time and uncertainty required to reconstruct a trustworthy patient story. Nightingale makes the Glance card a decision surface—not an AI summary. It shows at most five explainable risks, open actions, clinician-confirmed facts, and meaningful changes. Every item states why it matters and resolves to an exact immutable source span.

72-hour scope

Implemented: role-owned entries, longitudinal timeline, threaded coordination, tasks, full revisions and word diffs, append-only revert, deterministic 409 conflicts, patient-safe DTOs, three scribe interaction types, exact provenance, adaptive importance, SSE, and verified cold archive. Deliberately excluded: real LLM, voice capture, transcription, diarization, multilingual audio, and EHR integration.

System architecture



One TypeScript repository contains Next.js 16 UI, Route Handlers, SSE, and authorization. Prisma + better-sqlite3 provides a typed SQLite WAL store. The browser receives a random opaque session cookie; only its hash is stored. All object access is re-authorized by clinic or patient link. Unauthorized cross-scope objects return 404.

Privacy boundary

Free text is AES-256-GCM encrypted before persistence. Audit rows contain actor, action, object, version, and non-sensitive control metadata only. Scribe order is: encrypt raw synthetic source locally → redact known names, SG ID/NRIC/FIN-like values, and phones → call deterministic MockScribe with redacted text → encrypt summary and provenance. No key, model, or network request is used.

Patient safety is a server response property: patient DTOs contain only visibility=patient instructions; highlights, tasks, comments, raw AI notes, artifacts, and audit fields do not exist in the payload.

Data model and trust mechanics

The timeline stays authoritative while derived Glance signals remain explainable and reversible.

Cluster	Core records	Invariant
Identity / scope	Clinic, User, Session, Patient	Opaque cookie; clinic/patient checked on every object
Narrative	Entry, EntryVersion	Role owns Entry; body exists only in append-only versions
Collaboration	Comment, Task	Internal fields never enter patient DTO
AI / source	SourceArtifact, Highlight	System Entry remains distinct; exact version + span pointer
Trust / learning	Feedback, FeatureWeight, EntryRelation	Human action is auditable; correction supersedes, never erases
Operations	EventOutbox, AuditEvent, ArchiveBlob	Scoped SSE; metadata-only audit; verified transparent restore

Immutable revisions and deterministic conflicts

Entry stores role, owner, type, visibility, section, risk, current version, and optional source/supersession IDs. Body text exists only in EntryVersion snapshots. A write performs an atomic update where currentVersion equals baseVersion, then appends the encrypted snapshot. Different Entries succeed independently; the second writer to one Entry receives 409 VERSION_CONFLICT. The UI preserves its draft beside current server text. Revert decrypts a selected snapshot and appends a new version with revertedFromVersion; history is never deleted.

RBAC invariants

Staff can create/modify only their own staff entries; clinicians only their own clinician entries while reading staff/system context; patients can access only their linked record and patient-facing entries; admin is clinic-scoped and read-only in the prototype. Comments/tasks require internal collaborator status. The browser cannot assert a role: POST /api/session accepts only seeded server IDs.

Provenance and correction

A pointer is entryId + immutable versionId + character offsets + optional sourceArtifactId. Resolution repeats authorization, reads hot or cold content, validates its plaintext hash, and returns the exact slice. AI doctor, nurse, and patient sessions are distinct system Entries linked to their source session. A clinician correction creates a new Entry plus supersedes relation; the original patient/AI statement remains auditable while the corrected clinician source ranks higher.

Collaboration and realtime

Encrypted threaded comments support assignment and resolve/reopen. Tasks remain separate actionable records. Each mutation writes metadata-only audit plus a patient-scoped outbox event in the same transaction. A reconnectable 25-second SSE stream queries only after patient authorization; another browser refreshes without receiving unauthorized payload fields.

Trust is built by preserving disagreement. AI suggestions can be accepted, rejected, pinned, corrected, or traced—but never silently overwrite a human-owned section.

Importance, decay and evidence

Deterministic scoring plus conservative storage automation keeps behavior inspectable under time pressure.

Self-learning importance

Base score combines risk (critical +40, high +25, medium +10), unresolved task (+25), clinician confirmation (+15), entity (allergy +15, medication +10, chief complaint +8), and freshness (up to +15). Accept/pin adds +2 and reject –2 to a clinic-scoped featureKey weight, bounded to [–15,15]. Matching suggestions recompute finalScore = clamp(base + learned, 0, 100). Feedback, score, reason, and source remain auditable; rejection never removes provenance.

Conservative data decay

Eligible versions are older than 365 days, low-risk, have no open linked task, no accepted/pinned/high-risk highlight, and are not corrections or critical types. Preview is the default. Apply writes the original encrypted payload into gzip, encrypts it again with AES-256-GCM, rereads and hashes the blob, then marks SQL content cold. Metadata/pointers stay hot. Reads validate blob SHA-256, decrypt/decompress, and validate the original plaintext hash. Critical risk, allergy, open work, and correction are never auto-archived.

Measured acceptance

Warm path	Measured	Concurrency	P50	P95 / gate
50 requests	**200 requests**	**10**	**5.35 ms**	**9.55 ms · PASS < 300 ms**

Vitest verifies encryption, redaction-before-provider, scoring, and archive round-trip. Five brief-named Python files make real HTTP calls and run eight assertions covering cross-role writes, cross-clinic hiding, patient field omission, revisions/revert/metadata-only audit, exact spans, separate-entry concurrency, deterministic same-entry 409, and +2 learned score. A binary scan confirms known free-text phrases are absent from SQLite.

Trade-offs and next boundary

Choice	Why now	Production evolution
SQLite WAL	Zero-service, reproducible review	PostgreSQL + RLS + HA backups
Polling SSE	Small, inspectable collaboration path	Broker + durable outbox consumer
Demo cookie	No external auth dependency	OIDC/passkeys + CSRF + rotation
MockScribe	Proves redaction/provenance without disclosure	Approved model gateway + evals + DLP

Before real data: trusted TLS termination, managed identity, CSRF/rate limits, rotating secrets, formal threat modeling, retention policy, restore drills, clinical safety evaluation, accessibility testing, and observability without content. The prototype optimizes for trust boundaries and reproducibility—not compliance claims.